PHASE 1 REPORT: INFORMATION SECURITY POLICY & RISK ASSESSMENT

Akwaaba Steakhouse Enterprise Systems Infrastructure

Kennesaw State University
IT 4883 Infrastructure Defense

Team Members:

Sonny Wilson
Nicholas Coats
Axel Palacios
Jc Sparks

Date: October 2026

1 Project Status Update

Since the start of the semester, the team has successfully deployed, analyzed, and configured the Akwaaba Steakhouse server virtual machine environment on Red Hat Enterprise Linux (RHEL 8.4) [1, 2]. The team completed the baseline architectural analysis of the web application stack (Apache HTTP Server 2.4.37, MariaDB 10.6.4, and WordPress CMS), establishing GlobalProtect VPN remote administration access and verifying system user roles across the corporate HQ and store locations [1, 2]. Based on our preliminary discoveries, minor adjustments were made to the initial milestone schedule: task deadlines for technical file system hardening and ACL drafting were aligned directly with the NIST SP 800-30 Rev. 1 guidelines [3, 6].

From a project management perspective, minor initial hurdles were encountered regarding remote database access. These issues were resolved through team coordination by conducting meetings and standardizing access methods. Communication and workflow across team members remain on schedule, and all Phase 1 deliverables including the Information Security Policy, Access Management Matrix, and Server Risk Assessment have been finalized in full compliance with course milestones and industry standards [3, 4, 6].

2 Phase 1 Solution Report

2.1 Information Security Policy for Akwaaba Steakhouse

2.1.1 General Security Policy

Akwaaba Steakhouse operates two dining locations (NYC, Atlanta, LA) and corporate headquarters, employing ∼60 personnel [2]. This policy enforces administrative and technical controls to preserve the Confidentiality, Integrity, and Availability (CIA Triad) of Akwaaba's e-commerce platform and store operations [2, 4].

- **Internet Access & Network Use Policy:** Corporate networks and POS terminals are strictly reserved for authorized business processing; personal web browsing, streaming, and unauthorized software downloads are prohibited [3, 4]. POS terminals and database subnets are logically isolated from guest Wi-Fi via firewalls and VLANs [2, 3]. Direct public SSH (Port 22) or DB access is banned; remote access requires an authenticated GlobalProtect VPN session (`vpn.kennesaw.edu`) with Multi-Factor Authentication (MFA) enabled [1, 3].
- **Email & Electronic Communication Policy:** All corporate scheduling, customer communications, and financial correspondence must utilize company-issued email accounts [3, 4]. Email gateways enforce anti-phishing, DKIM, and SPF protocols; staff are strictly forbidden from opening unverified attachments [3, 4]. Transmitting primary account numbers (PAN) or unencrypted employee PII over email is strictly prohibited [3, 4].
- **Bring Your Own Device (BYOD) Policy:** Personal employee devices are strictly banned from connecting to internal POS networks or backend database subnets [2, 3]. Corporate access on personal mobile devices (HQ staff only) requires registration in Enterprise Mobile Device Management (MDM) with mandatory full-disk encryption and remote wipe capabilities [3].
- **Password & Authentication Controls:** All passwords must be at least 14 characters, combine uppercase, lowercase, numeric, and special symbols, and rotate every 90 days [3]. Default administrative passwords (e.g., initial MariaDB passwords) must be changed immediately upon installation [2, 3]. Accounts lock for 30 minutes after 5 failed login attempts [3].

2.1.2 Access Management Policy

Akwaaba enforces Role-Based Access Control (RBAC) and Least Privilege principles [3, 4]. System permissions strictly correspond to job function, governed by the Bell-LaPadula confidentiality model (Simple Security: *No Read Up*; $\star$-Property: *No Write Down*) [4].

Table 1: Akwaaba Role-Based Access Control (RBAC) & Resource Matrix

Role / Position	Count	Assigned Systems & Scope	Access Level & Privileges	Authentication Basis
Owner / Executive	1	Corporate Financials, Sales Reports	Read-Only access to aggregate revenue logs [2].	Corporate Login + MFA [3]
General Manager	3	Store POS, Local Inventory, Schedules	Read/Write to local store POS & schedules [2].	Local POS PIN + Password [3]
Waiters / Host / Bartender	∼50	Front-of-House POS Terminals	Transactional execute-only (Order entry/billing) [2].	Unique Employee ID / PIN [3]
Cooks / Bussers	∼15	Kitchen Display System (KDS)	Read-Only access to active order queue [2].	Terminal ID [3]
Chief Accountant	1	MariaDB, Financial Ledgers, Payroll	Read/Write access to accounting databases [2].	Corporate Domain + MFA [3]
HR Agents	2	HR Portal, Employee PII Records	Read/Write access to personnel/payroll files [2].	Corporate Domain + MFA [3]
Web Developer	1	Web Root (`/var/www/html`), CMS	Read/Write access to CMS (`wp-admin`); restricted shell [2].	SSH Key + MFA [1, 3]
System Administrator	1	RHEL OS, Apache, MariaDB Engine	Full Root / Sudo administrative control [2].	SSH Key + VPN + MFA [1, 3]

2.1.3 Technical System Hardening & ACL Implementation

POSIX permissions and Linux File System Access Control Lists (ACLs) enforce strict boundary isolation on the RHEL 8.4 server [2, 4]:

1. **Web Root Hardening (`/var/www/html/home`):** Ownership set to `apache:apache` with directory permissions `750` (`rwxr-x---`) and file permissions `640` (`rw-r-----`) [2, 4].
2. **WordPress Configuration (`wp-config.php`):** Permissions restricted to `600` (`rw-------`) owned by `apache:apache` [2, 4].
3. **PHP-FPM Process Isolation (`/etc/php-fpm.d/www.conf`):** Execution restricted via `listen.acl_users = apache` [2].
4. **Granular Developer ACLs:** Enforced via POSIX ACL: `sudo setfacl -R -m u:webdev:rwx /var/www/html/home` [4].

2.2 Risk Assessment on the Akwaaba Server

2.2.1 Overall Evaluation of Server Infrastructure

Akwaaba Steakhouse operates a centralized e-commerce and operational server environment hosted on RHEL 8.4 [2]. The technical stack consists of Apache HTTP Server 2.4.37, MariaDB Database 10.6.4, and a WordPress CMS instance (`/var/www/html/home`) supporting web e-commerce operations and multi-location dining services [2]. Remote administration is conducted via SSH (Port 22) restricted through a GlobalProtect VPN gateway (`vpn.kennesaw.edu`) [1]. Baseline security evaluation reveals initial configuration exposures in `wp-config.php`, overly broad default PHP-FPM execution permissions (`listen.acl_users = apache, nginx`), and administrative backend login portals (`/wp-admin`) relying on static default credentials (`Kennesaw123!`) lacking MFA and rate-limiting [2, 5].

2.2.2 Important Assets to Protect

In accordance with NIST SP 800-30 Rev. 1, enterprise assets are categorized into Digital and People assets [2, 6]:

- **Digital Assets:** Customer Payment & Transaction Data (MariaDB database tables, payment logs); E-Commerce Application Platform (WordPress web files, site configurations, Apache server); Server Operating System & Infrastructure (RHEL 8.4 host, system root, SSH service, PHP-FPM engine); Corporate Financial & HR Records (general ledgers, payroll profiles, employee PII) [2].
- **People Assets:** Corporate Administrative Staff (1 Owner, 1 Chief Accountant, 2 HR Agents, 1 Web Developer); Store Operational Personnel (∼50 store staff including General Managers, Waiters, Hosts, Bartenders, and Kitchen Cooks) [2].

2.2.3 Risk Assessment Matrix

Table 2: Akwaaba Enterprise Server Risk Assessment Matrix

Assets	Threats / Risks	Possibilities of Successful Compromise	Damage if Asset Compromised
Customer Payment & Transaction Data *(Digital Asset)*	**SQL Injection (SQLi) / DB Breach:** Exploitation of unvalidated web inputs or unpatched plugins to exfiltrate cardholder logs [2, 5].	**Moderate (5)** High if web inputs remain unvalidated and MariaDB default configurations remain exposed [2, 5].	**Severe / Critical (10)** Severe PCI-DSS fines, brand destruction, financial liability, and legal lawsuits [3, 5].
E-Commerce Platform & Web Server *(Digital Asset)*	**Brute-Force / Credential Stuffing:** Automated login attacks against `/wp-admin` exploiting weak passwords (`Kennesaw123!`) to deface the site [2, 5].	**High (8)** Publicly accessible admin endpoints are continuously targeted by automated threat bots [5, 6].	**High (8)** E-commerce downtime, lost online sales revenue, site defacement, and customer loss [3, 5].
Server Host OS & Infrastructure *(Digital Asset)*	**Privilege Escalation & SSH Takeover:** Local escalation via world-readable configuration files (`wp-config.php`) leading to root takeover [2, 5].	**Moderate (5)** Requires initial VPN/web foothold, but high success if permissions remain unhardened (`644`) [2, 5].	**Catastrophic (10)** Complete loss of system control, ransomware deployment, malicious wiper execution, and shutdown [3, 5].
Corporate Financial & HR Data *(Digital Asset)*	**Unauthorized Access / Exfiltration:** Internal privilege abuse or exfiltration of unencrypted accounting ledgers and employee PII [2, 5].	**Low to Moderate (2-5)** Dependent on backend database user privilege separation and network ACL enforcement [2, 5].	**High (8)** Regulatory privacy fines, employee identity theft, payroll fraud, and internal disruption [3, 5].
Administrative Staff & Store Personnel *(People Asset)*	**Spear-Phishing / Social Engineering:** Targeted email phishing directed at HQ staff to harvest credentials or deploy malware [2, 5].	**Moderate (5)** Human error remains a persistent threat vector across corporate email channels [5, 6].	**Moderate to High (5-8)** Secondary credential theft, compromised financial workflows, and network entry vector [3, 5].

References

[1] Instructions Connecting to VM, Kennesaw State University, Fall 2026.

[2] VM Server Configuration Template 2 Akwaaba v2, Kennesaw State University, Fall 2026.

[3] IT 4883 Infrastructure Defense - Cybersecurity Server Hardening Draft 1 Guide, Fall 2026.

[4] L. Li, "Information Security Policy & Access Control," IT 6823/4883 Lecture Slides, Kennesaw State University, Fall 2026.

[5] L. Li, "Risk Management," IT 6823/4883 Lecture Slides, Kennesaw State University, Fall 2026.

[6] Joint Task Force Transformation Initiative, *Guide for Conducting Risk Assessments*, NIST Special Publication 800-30, Rev. 1, Sep. 2012.